

BLACKBOX API TEST REPORT

Sellica Golang Backend

Date:	2026-07-17
Target:	http://localhost:8081
Branch:	feat/supabase-jwt
Framework:	Go 1.23 + Gin v1.10
Tests:	130 cases across 17 suites
Total Endpoints:	~114 across 18 route groups

1. Executive Summary

Metric	Count	Percentage
Total Tests	130	100%
Passed	108	83.1%
Failed	11	8.5%
Skipped	11	8.5%

Overall: Backend API is mostly solid (83% pass). Key issues: SILPANA ticket creation (500), missing admin seed, unprotected concurrent endpoints.

2. Security Assessment

Security Test	Result	Detail
SQL Injection	PASS	All inputs validated, returns 400
XSS Attacks	PASS	Input sanitized, no script execution
Path Traversal	PASS	Returns 404 for all attempts
Null Bytes	PASS	Rejected by validator
CORS Preflight	PASS	OPTIONS returns 204
Auth: No Token	PASS	Protected endpoints return 401
Auth: Invalid Token	PASS	Returns 401 with clear error
Auth: Wrong Format	PASS	Returns 401 for malformed Bearer
Large Payloads	PASS	Handled gracefully
Invalid Methods	PASS	Returns 404/405
Concurrent Endpoints	FAIL	NO authentication required
Rate Limiting	WARN	Header-only, no enforcement

Key Concerns:

- Concurrent endpoints (10 routes) have NO auth — anyone can modify rate limits, reset circuit breakers
- Rate limiting is header-only (X-RateLimit headers returned) but not enforced server-side

3. API Endpoint Inventory

Category	Endpoints	Auth	Status
Health & Metrics	8	Public	PASS
Auth (Register/Login)	6	Public/Protected	PASS
SILPANA Ticketing	10	Protected	PARTIAL
Aktivitas SIAK	7	Protected	PASS
Data Rekam	5	Protected	PASS
Admin	3	Admin-only	PASS
Supabase Analyzer	4	Admin-only	PASS
Concurrent Processing	10	NONE	FAIL
Performance	5	Mixed	PASS
Database & Cache	7	Mixed	PASS
Chat	4	Mixed	PASS
Salah Rekam	2	Protected	PASS

Total: ~114 endpoints across 12 categories

4. Detailed Test Results

4.1 Authentication Tests (20 cases)

#	Test Case	Exp	Act	R
1	POST /auth/register valid data	200	200	PASS
2	POST /auth/register empty body	400	400	PASS
3	POST /auth/register missing email	400	400	PASS
4	POST /auth/register missing name	400	400	PASS
5	POST /auth/register missing password	400	400	PASS
6	POST /auth/register weak pw (short)	400	400	PASS
7	POST /auth/register weak pw (no upper)	400	400	PASS
8	POST /auth/register weak pw (no digit)	400	400	PASS
9	POST /auth/register weak pw (no special)	400	400	PASS
10	POST /auth/register invalid email	400	400	PASS
11	POST /auth/register SQL injection	!=500	400	PASS
12	POST /auth/register XSS in name	!=500	409	PASS
13	POST /auth/register null byte	!=500	409	PASS
14	POST /auth/login invalid creds	401	401	PASS
15	POST /auth/login missing email	400	400	PASS
16	POST /auth/login SQL injection	!=500	400	PASS
17	POST /auth/login XSS in email	!=500	400	PASS
18	GET /auth/profile no token	401	401	PASS

19	POST /auth/refresh no token	401	401	PASS
20	OPTIONS /auth/login preflight	204	204	PASS

4.2 SILPANA Ticketing Tests (17 cases)

#	Test Case	Exp	Act	R
50	POST /tickets valid data	200	500	FAIL
51	POST /tickets returns ID	non-empty	empty	FAIL
52	POST /tickets unicode	!=500	500	FAIL
53	POST /tickets empty body	400	400	PASS
54	GET /tickets list	200	200	PASS
56	GET /tickets/invalid-id	404 401	401	PASS
57	POST /tickets/lookup	404	404	PASS
58	GET /silpana/health	200	200	PASS
59	POST /tickets/bulk-approve	400	400	PASS
60	POST /tickets/bulk-reject	400	400	PASS
61	DELETE /tickets/bulk-delete	400	400	PASS
62	GET /silpana/stats	200	200	PASS
63	GET /silpana/progress/TEST	404	404	PASS
64	POST /tickets empty body	400	400	PASS
65	POST /tickets SQLi	!=500	500	FAIL
66	POST /tickets XSS	!=500	500	FAIL

Root Cause: Ticket creation 500 — missing Supabase table or connection on feat/supabase-jwt.

4.3 Concurrent Processing Tests (10 cases)

#	Test Case	Exp	Act	R
88	GET /concurrent/status	200 404	200	PASS
89	GET /concurrent/metrics	200 404	200	PASS
90	GET /concurrent/health	200 404	200	PASS
91	GET /worker-pool/status	200 404	200	PASS
92	GET /worker-pool/metrics	200 404	200	PASS
93	GET /rate-limiter/status	200 404	200	PASS
94	PUT /rate-limiter/limit	200 400	400	PASS
95	GET /circuit-breaker/status	200 404	200	PASS
96	POST /circuit-breaker/reset	200 404	200	PASS
97	GET /metrics/detailed	200 404	200	PASS

WARNING: All concurrent endpoints pass BUT have no authentication — security risk!

4.4 Other Tests (Health, Data Rekam, Chat, etc.)

#	Test Case	Exp	Act	R
7-8	GET /metrics, /metrics/health, /summary	200	200	PASS
67	GET /data-rekam/adjudicate	200 401	200	PASS
68	GET /data-rekam/duplicate-operator	200 401	200	PASS
70	GET /data-rekam/pengajuan-bulanan	200 401	200	PASS
72	GET /data-rekam/dashboard-stats	200 401	200	PASS
81	GET /api/v1/supabase/overview	200 401	200	PASS
100	GET /performance	200	200	PASS
105	GET /database/health	200	200	PASS
109	GET /cache/health	200	200	PASS
123	POST /chat valid	200	200	PASS
128	POST /api/chat	200	200	PASS
115	GET path traversal	404	404	PASS
116	DELETE /auth/login (wrong method)	405	404	PASS
129	GET /api/v1/salah-rekam no auth	401	401	PASS

4.5 Skipped Tests — No Auth Token (11 cases)

#	Test Case	Reason
40	GET /auth/profile (with token)	No valid JWT token
41	POST /auth/refresh (with token)	No valid JWT token
42	POST /auth/logout (with token)	No valid JWT token
55	GET /silpana/tickets/:id	No ticket ID available
69	Aktivitas SIAK CRUD with auth	No valid JWT token
75	Data Rekam with auth	No valid JWT token

79	Admin non-admin access	No valid JWT token
80	Admin with admin token	No admin token
85	Supabase with admin token	No admin token
86	Supabase non-admin access	No non-admin token
130	Salah Rekam with auth	No valid JWT token

5. Recommendations

- [CRITICAL] Add authentication to concurrent endpoints (/api/concurrent/*)
- [CRITICAL] Fix SILPANA ticket creation (500 error) — check Supabase table migration
- [HIGH] Seed admin user for full auth-flow testing
- [HIGH] Enforce rate limiting (currently header-only)
- [MEDIUM] Standardize response format across all handlers (5+ patterns found)
- [MEDIUM] Move /chat/auth from handler-level to middleware
- [LOW] Add request body size limits for all endpoints
- [LOW] Add OpenAPI/Swagger documentation

6. Authentication Flow Analysis

- Client sends POST /auth/login with {email, password}
- Backend validates email format + password presence
- Backend queries Supabase Auth for user credentials
- If valid: generates JWT token with user_id, email, role
- Returns {success: true, token: 'eyJ...', user: {...}}
- Client stores token in localStorage
- Subsequent requests: Authorization: Bearer
- Middleware: ValidateToken() -> extract user_id/email/role
- Handler accesses user info from gin.Context

7. Middleware Chain

Order	Middleware	Purpose
1	RequestID	Generate unique request ID
2	ResponseTime	Track response latency
3	SecurityHeaders	X-Frame-Options, CSP, etc.
4	Logging	Request/response logging
5	CORS	Cross-origin (dev: allow all)
6	OptionalAuth	Parse JWT if present (non-blocking)
7	RateLimit	Header-based (not enforced)
8	RequiredAuth	Block if no valid token (protected)
9	AdminOnly	Block if role != admin/superuser